Malware-Oriented Privilege Escalation Simulation and Analysis Framework for Windows Systems

A B.Tech project report submitted in partial fulfillment of the requirements for the award of the degree of

Bachelor of Technology

by

Himanshu Parate

(Reg. No. 2022BCS056)

Under the Supervision of

Dr. A. V. Nandedkar

Department of Computer Science and Engineering

Shri Guru Gobind Singhji Institute of Engineering and Technology

Nanded - 431606, India

May, 2026

Report Approval

This report entitled **Malware-Oriented Privilege Escalation Simulation and Analysis Framework for Windows Systems** by **Himanshu Parate**, Reg. No. 2022BCS056, is approved for the degree of **Bachelor of Technology** from Shri Guru Gobind Singhji Institute of Engineering and Technology.

Dr. A. V. Nandedkar	Prof. A. M. Bainwad	Prof. P. P. Kanhegaonkar
(Project Guide)	*(Head of Department)*	*(Project Coordinator)*

Date: 4 May 2026

Place: Nanded

Certificate

This is to certify that the report entitled **"Malware-Oriented Privilege Escalation Simulation and Analysis Framework for Windows Systems"**, submitted by **Himanshu Parate** to Shri Guru Gobind Singhji Institute of Engineering and Technology, for the award of the degree of **Bachelor of Technology in Computer Science and Engineering**, is a record of the original, bonafide research work carried out by him under our supervision and guidance. The report has reached the standards fulfilling the requirements of the regulations related to the award of the degree.

The results contained in this report have not been submitted in part or in full to any other University or Institute for the award of any degree or diploma to the best of our knowledge.

Dr. A. V. Nandedkar
Department of Computer Science and Engineering,
Shri Guru Gobind Singhji Institute of Engineering and Technology

---

Prof. A. M. Bainwad
Head of Department
Shri Guru Gobind Singhji Institute of Engineering and Technology

---

Prof. P. P. Kanhegaonkar
Project Coordinator
Shri Guru Gobind Singhji Institute of Engineering and Technology

Declaration

I declare that this written submission represents my ideas in my own words and where others' ideas or words have been included, I have adequately cited and referenced the original sources. I also declare that I have adhered to all principles of academic honesty and integrity and have not misrepresented or fabricated or falsified any idea/data/fact/source in my submission. I understand that any violation of the above will be cause for disciplinary action by the Institute and can also evoke penal action from the sources which have thus not been properly cited or from whom proper permission has not been taken when needed.

Himanshu Parate

Reg. No.: 2022BCS056

Date: May 2026

Place: SGGS Nanded

Acknowledgements

I take this opportunity to acknowledge and express my gratitude to all those who supported and guided me during the dissertation work. I am grateful to the Almighty for the abundant grace and blessings that enabled me to complete this dissertation successfully.

Himanshu Parate
Reg. No.: 2022BCS056
Department of Computer Science and Engineering
Shri Guru Gobind Singhji Institute of Engineering and Technology

Abstract

Malviz is a cybersecurity-focused system designed to monitor, analyze, and visualize system-level activities for the purpose of detecting suspicious or malicious behavior. The project aims to bridge the gap between raw system telemetry and actionable insights by providing an intuitive and interactive interface for analyzing process execution, privilege escalation attempts, and anomalous system behavior.

The system collects real-time data from operating system processes, including process creation, resource usage, and parent-child relationships, and transforms this data into structured logs and visual representations. By leveraging visualization techniques, Malviz enables users to identify hidden patterns, trace attack chains, and understand complex system interactions more effectively than traditional log-based approaches.

Malviz is particularly useful for security researchers, students, and professionals interested in malware analysis, threat detection, and system monitoring. It can serve as a lightweight alternative or complementary tool to traditional SIEM systems by focusing on process-level insights and behavioral analysis. The modular architecture allows for future integration with network monitoring, alerting systems, and machine learning-based anomaly detection.

Overall, Malviz provides a practical and extensible platform for exploring system internals, detecting threats, and enhancing situational awareness in cybersecurity environments.

Contents

Approval

Certificate

Declaration

Acknowledgements

Abstract

Contents

List of Figures

List of Tables

Abbreviations

Symbols

1 Introduction **1**
1.1 Introduction 1
1.2 Problem Statement 1
1.3 Need of the Study 2
1.4 Study Objective 2
1.5 Dissertation Organization 3
1.6 Summary 3

2 Literature Review **4**
2.1 Introduction 4
2.2 Windows Architecture 5
2.3 System Calls and NTDLL 6
2.4 Hell's Gate Technique 7
2.4.1 Hell's Gate Technique for Direct System Call Resolution . . . 8

2.4.1.1 Export Address Table Traversal 8
2.4.1.2 System Call Extraction 9
2.4.1.3 Executing System Calls Using Hell's Gate 10
2.5 Privilege Escalation Techniques 11
2.6 SAM Hash Extraction 12
2.7 Privilege Escalation Attack Workflow 12
2.8 Research Gap 13
2.9 Summary 13

3 Study Methodology **14**
3.1 Research Approach 14
3.2 Experimental Environment 14
3.3 Data Collection 15
3.4 Malware Analysis Process 15
3.5 Privilege Escalation Analysis 16
3.6 System Call Analysis using Hell's Gate 17
3.7 Malviz Visualization Framework 17
3.7.1 Malware Analysis Workflow 18
3.8 Evaluation 18
3.9 Summary 18

4 System Design and Implementation **20**
4.1 Introduction 20
4.2 System Architecture 20
4.3 Backend Modules 22
4.3.1 Application Entry Point (main.py) 22
4.3.2 Process Inspector (inspector.py) 22
4.3.3 Threat Detection Engine (threat_engine.py) 23
4.3.4 Database Layer (database.py) 24
4.4 Frontend Dashboard 25
4.5 Attack Simulation Scripts 25
4.6 Technology Stack 26
4.7 Entity-Relationship (ER) Diagram 26
4.7.1 Database Schema ER Diagram 27
4.7.2 Full System Entity-Relationship Diagram 27
4.8 Software Development Life Cycle (SDLC) Model 29
4.8.1 Choice of SDLC Model 29
4.8.2 Waterfall Model Applied to Malviz 30
4.8.3 Phase Descriptions 30
4.9 Summary 31

5 Analysis and Results **32**

5.1 Introduction 32
5.2 Detection Results 32
5.3 False Positive Analysis 33
5.4 Process Inspector Results 34
5.4.1 SHA-256 Hash Validation 34
5.4.2 PE Header and Import Analysis 34
5.4.3 Token Integrity Level 34
5.5 Network Analysis Results 35
5.6 System Performance 35
5.7 Threat History, Alerting, and Persistence 35
5.8 Summary 36

6 Conclusions and Practical Implications **37**
6.1 Summary 37
6.2 Study Findings 37
6.3 Research Contributions 38
6.4 Practical Implications 39
6.5 Study Limitations and Scope for Future Work 40

A Attack Simulation Scripts **41**

B API Endpoint Reference **46**

List of Figures

2.1 Windows User Mode and Kernel Mode Architecture 5
2.2 Windows Architecture 6
2.3 Hell's Gate System Call Resolution Process 7
2.4 Privilege Escalation Attack Workflow 12

3.1 Malviz Malware Analysis Workflow 18

4.1 Malviz System Architecture 21
4.2 Real-Time Alert and Escalation Tracking Workflow 21
4.3 ER Diagram — Malviz SQLite Database Schema 27
4.4 Full System ER Diagram — Entity Relationships in Malviz 28
4.5 Waterfall SDLC Model Applied to Malviz Development 30

List of Tables

3.1 Experimental Environment Setup 15

4.1 Attack Simulation Scripts and Expected Detections 26
4.2 Malviz Technology Stack 26

5.1 Simulation Detection Results 33
5.2 Malviz System Performance During Testing 35

B.1 WebSocket Streaming Endpoint 46
B.2 Malviz REST API Endpoint Reference 47

Abbreviations

API	**A**pplication **P**rogramming **I**nterface
DLL	**D**ynamic **L**ink **L**ibrary
DNS	**D**omain **N**ame **S**ystem
EAT	**E**xport **A**ddress **T**able
EDR	**E**ndpoint **D**etection and **R**esponse
ETW	**E**vent **T**racing for **W**indows
LOLBin	**L**iving **O**ff the **L**and **Bin**ary
NTLM	**N**ew **T**echnology **L**AN **M**anager
PE	**P**ortable **E**xecutable
PEB	**P**rocess **E**nvironment **B**lock
PID	**P**rocess **ID**entifier
SAM	**S**ecurity **A**ccount **M**anager
SIEM	**S**ecurity **I**nformation and **E**vent **M**anagement
SPA	**S**ingle **P**age **A**pplication
TCP	**T**ransmission **C**ontrol **P**rotocol
UDP	**U**ser **D**atagram **P**rotocol

Symbols

`0xB3`	Example syscall number (NtCreateMutant)
`RSS`	Resident Set Size (memory metric)
`PID`	Numeric process identifier assigned by Windows

Chapter 1

Introduction

1.1 Introduction

Malware continues to evolve rapidly, posing serious threats to modern computer systems. Traditional signature-based detection methods often fail to detect new or obfuscated malware. Therefore, malware analysis has become essential for understanding malicious behavior and attack patterns. However, the raw data generated during malware analysis is often complex and difficult to interpret. **Malviz** addresses this challenge by transforming malware behavior into intuitive visual patterns, making analysis faster and more accessible for security analysts.

1.2 Problem Statement

Malware is becoming increasingly sophisticated and difficult to detect using traditional security methods. Signature-based detection techniques frequently fail to identify new, unknown, or polymorphic malware. Malicious programs often perform hidden system-level activities such as privilege escalation, suspicious system calls, and abnormal process behavior. Manually analyzing these behaviors from raw logs and analysis reports can be complex, time-consuming, and inefficient for security analysts.

1.3 Need of the Study

With the rapid growth of digital infrastructure, malware attacks have become more frequent and sophisticated. Traditional malware detection techniques mainly rely on signature-based approaches, which are often ineffective against new or obfuscated malware variants. Security analysts usually depend on large volumes of logs, system calls, and behavioral reports generated during malware analysis. However, interpreting this raw data can be complex, time-consuming, and prone to human error.

There is a growing need for tools that can simplify malware analysis and help analysts quickly understand malicious behavior. Visual representation of malware activity can make patterns easier to identify and improve the efficiency of security investigations. Therefore, this study focuses on developing **Malviz**, a system that converts malware behavior into intuitive visual patterns, enabling faster and more effective malware analysis.

1.4 Study Objective

The primary objective of this study is to design and develop a system that visualizes malware behavior to simplify the analysis process for security researchers and analysts.

- To analyze malware behavior based on system-level activities such as system calls, process actions, and privilege changes.
- To transform raw malware analysis data into meaningful visual representations.
- To help analysts quickly identify suspicious patterns and abnormal behavior.
- To provide an intuitive and accessible platform for malware behavior visualization.

1.5 Dissertation Organization

This dissertation consists of six chapters, including the present chapter (Chapter 1), which introduces the research topic. This chapter describes the need for the study, the problem statement, and the objectives of the research.

Chapter 2 presents a review of existing literature related to malware analysis techniques, malware visualization approaches, and cybersecurity tools used for behavior analysis.

Chapter 3 explains the methodology adopted for the development of the **Malviz** system, including data collection, malware behavior extraction, and visualization techniques.

Chapter 4 describes the implementation details of the proposed system, including system architecture, tools used, and data processing techniques.

Chapter 5 presents the results obtained from testing the system and discusses how visualization helps in understanding malware behavior.

Finally, Chapter 6 summarizes the conclusions of the research and highlights the contributions and possible future improvements.

1.6 Summary

This chapter introduced the background and motivation for the study and explained the need for improved malware analysis methods. The objectives of the research were presented, focusing on the development of the **Malviz** system for malware behavior visualization. In addition, the overall structure of the dissertation was outlined to provide a clear overview of the research organization.

Chapter 2

Literature Review

2.1 Introduction

Malware analysis and privilege escalation attacks have become critical areas of research in modern cybersecurity. With the increasing number of cyber-attacks targeting operating systems such as Microsoft Windows, advanced techniques have been developed to detect, analyze, and mitigate malicious software.

Windows operating systems rely on several internal components such as dynamic link libraries (DLLs), system calls, kernel services, and access control mechanisms. Libraries such as **Kernel32.dll**, **Ntdll.dll**, and **User32.dll** provide an interface between user applications and the Windows kernel.

Attackers exploit vulnerabilities in these components to gain elevated privileges or execute malicious code. Privilege escalation attacks allow attackers to obtain administrative or kernel-level access and perform unauthorized operations within the system.

These attacks are generally categorized into two types:

- Horizontal Privilege Escalation
- Vertical Privilege Escalation

Recent research focuses on advanced techniques such as dynamic malware analysis, behavioral monitoring, and direct system call execution techniques such as the **Hell's Gate technique**.

—

2.2 Windows Architecture

Understanding Windows internal architecture is essential for malware analysis.

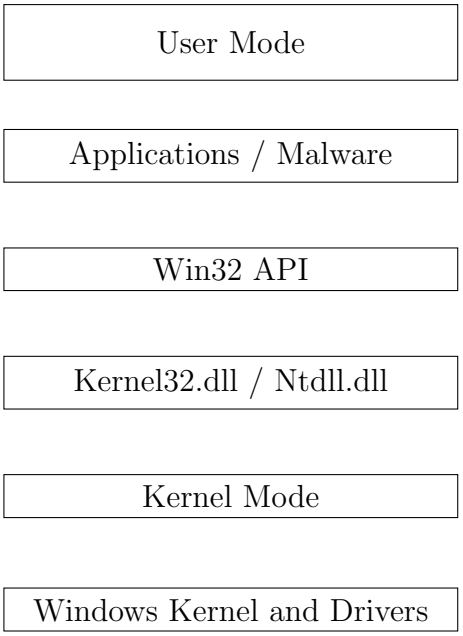

FIGURE 2.1: Windows User Mode and Kernel Mode Architecture

Applications interact with the operating system using the Win32 API. These APIs eventually trigger system calls that transfer execution from user mode to kernel mode.

Applications interact with the Windows operating system using **Win32 APIs**, which are implemented in libraries such as:

- `kernel32.dll`
- `ntdll.dll`

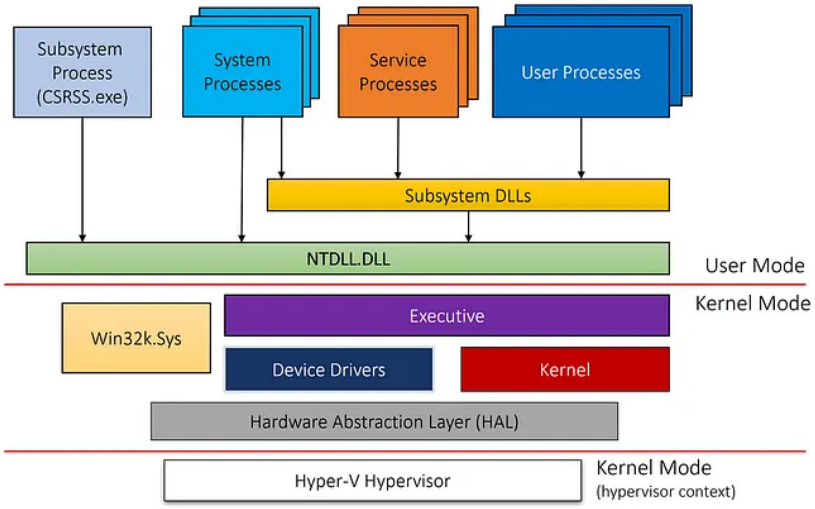

FIGURE 2.2: Windows Architecture

- `advapi32.dll`

These APIs eventually invoke **system calls** that transition execution from *user mode* to *kernel mode*.

2.3 System Calls and NTDLL

The **NTDLL.dll** library plays a crucial role in Windows internals because it provides the interface for executing system calls. Each user-mode process implicitly links against NTDLL, which contains wrappers that transition execution to kernel mode.

A typical system call implementation follows this pattern:

```
mov r10, rcx
mov eax, syscall_number
syscall
ret
```

The `syscall` instruction transfers execution to the Windows kernel where privileged operations are performed.

2.4 Hell's Gate Technique

The Hell's Gate technique is a modern malware technique that dynamically retrieves system call numbers from NTDLL instead of relying on static API calls.

Traditional malware relies on functions such as:

```
LoadLibrary()
GetProcAddress()
```

However, these APIs are frequently monitored by security solutions such as antivirus and endpoint detection systems.

Hell's Gate bypasses this monitoring by directly resolving system calls from memory.

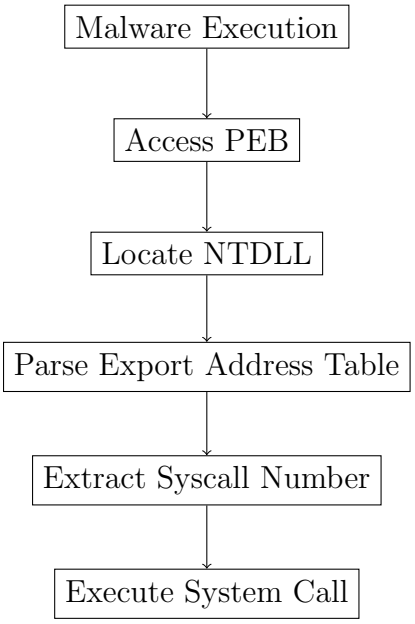

FIGURE 2.3: Hell's Gate System Call Resolution Process

This technique allows malware to evade many detection mechanisms by avoiding monitored API functions.

—

2.4.1 Hell's Gate Technique for Direct System Call Resolution

The Hell's Gate technique is a modern malware evasion technique that allows programs to dynamically resolve and execute Windows system calls without relying on standard API functions. Instead of invoking Windows API functions such as `LoadLibrary` or `GetProcAddress`, Hell's Gate directly retrieves system call numbers from the `NTDLL.dll` module at runtime.

The main objective of the Hell's Gate technique is to locate and traverse the Export Address Table (EAT) of `NTDLL.dll` in memory and dynamically extract the system call numbers associated with internal NT functions such as `NtCreateMutant`, `NtAllocateVirtualMemory`, and others.

2.4.1.1 Export Address Table Traversal

To locate system calls dynamically, the technique traverses the Portable Executable (PE) structure of `NTDLL.dll`. The process involves several steps:

1. Retrieve the base address of the loaded module.
2. Access the `_IMAGE_DOS_HEADER` and verify the `IMAGE_DOS_SIGNATURE`.
3. Traverse the `_IMAGE_NT_HEADERS`, `_IMAGE_FILE_HEADER`, and `_IMAGE_OPTIONAL_HEADER`.
4. Locate the Export Address Table inside the `_IMAGE_DATA_DIRECTORY`.
5. Typecast the structure to `_IMAGE_EXPORT_DIRECTORY`.

The following code illustrates how the Export Address Table can be accessed from memory:

```
PPEB Peb = (PPEB)__readgsqword(0x60);
PLDR_MODULE pLoadModule;
PBYTE ImageBase;

pLoadModule = (PLDR_MODULE)((PBYTE)
Peb->LoaderData->InMemoryOrderModuleList.Flink->Flink - 16);
```

```
ImageBase = (PBYTE)pLoadModule->BaseAddress;
```

After retrieving the base address, the PE structures are parsed sequentially:

```
    PIMAGE_DOS_HEADER Dos = (PIMAGE_DOS_HEADER)ImageBase;

if (Dos->e_magic != IMAGE_DOS_SIGNATURE)
    return 1;

PIMAGE_NT_HEADERS Nt =
(PIMAGE_NT_HEADERS)((PBYTE)Dos + Dos->e_lfanew);

PIMAGE_FILE_HEADER File =
(PIMAGE_FILE_HEADER)(ImageBase +
(Dos->e_lfanew + sizeof(DWORD)));

PIMAGE_OPTIONAL_HEADER Optional =
(PIMAGE_OPTIONAL_HEADER)((PBYTE)File +
sizeof(IMAGE_FILE_HEADER));

PIMAGE_EXPORT_DIRECTORY ExportTable =
(PIMAGE_EXPORT_DIRECTORY)
(ImageBase + Optional->DataDirectory[0].VirtualAddress);
```

Once the Export Address Table is reached, it contains several important arrays:

- FunctionNameAddressArray – contains function names
- FunctionOrdinalAddressArray – indexes for functions
- FunctionAddressArray – addresses of exported functions

These arrays allow traversal of exported functions within `NTDLL.dll`.

2.4.1.2 System Call Extraction

Each NT system function follows a common instruction pattern that loads the system call number into the `EAX` register before executing the `syscall` instruction.

Example disassembly:

```
    mov r10, rcx
mov eax, 0B3h
syscall
ret
```

Here, the system call number (`0xB3`) is loaded into the `EAX` register and executed using the `syscall` instruction.

The system call identifier can be extracted from the function's instruction bytes:

```
    db (ntdll!NtCreateMutant + 0x4) L 2
00007fff`b040c3d4 b3 00
```

The syscall value is calculated as:

```
    (0x00 << 8) | 0xb3 = 179
```

2.4.1.3 Executing System Calls Using Hell's Gate

Once the syscall number is extracted, Hell's Gate uses a small assembly routine to dynamically execute the syscall.

```
    .data
wSystemCall DWORD 000h

.code
HellsGate PROC
    mov wSystemCall, ecx
    ret
HellsGate ENDP

HellDescent PROC
    mov r10, rcx
    mov eax, wSystemCall
    syscall
    ret
HellDescent ENDP
```

The `HellsGate` function stores the syscall number, while `HellDescent` executes the syscall instruction.

Example usage:

```
    WORD syscall = 0x00b3;

HellsGate(syscall);

HANDLE hMutant = INVALID_HANDLE_VALUE;

NTSTATUS st =
HellDescent(&hMutant, MUTANT_ALL_ACCESS, NULL, TRUE);
```

This approach allows malware or red-team tools to bypass traditional API monitoring mechanisms and execute system calls directly, thereby evading detection mechanisms implemented by security products such as antivirus or EDR systems.

2.5 Privilege Escalation Techniques

Privilege escalation attacks occur when attackers gain higher permissions than originally assigned to them.

Common privilege escalation methods include:

- DLL Hijacking
- Token Impersonation
- Unquoted Service Path Exploitation
- SAM Hash Extraction

—

2.6 SAM Hash Extraction

The **Security Account Manager (SAM)** database stores user authentication information in Windows systems.

The SAM file is located at:

```
C:\Windows\System32\config\SAM
```

Attackers extract password hashes from the SAM file using tools such as **secretsdump**.

```
secretsdump.py -sam SAM -security SECURITY -system SYSTEM local
```

Extracted hashes are then cracked using password recovery tools such as **Hashcat**.

—

2.7 Privilege Escalation Attack Workflow

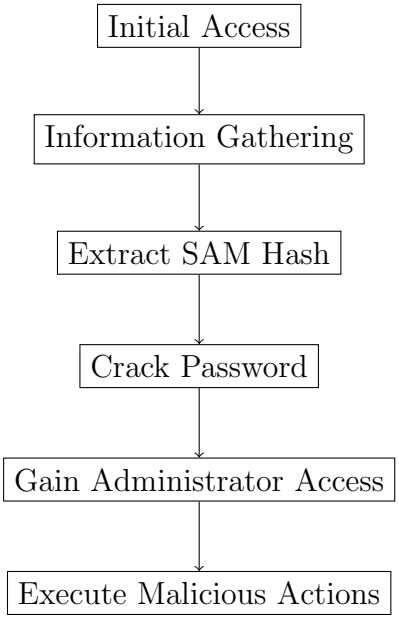

Figure 2.4: Privilege Escalation Attack Workflow

—

2.8 Research Gap

Despite advancements in malware detection techniques, many security systems still rely on signature-based detection and API monitoring. Modern malware techniques such as direct system calls and dynamic syscall resolution allow attackers to bypass these detection mechanisms.

Therefore, new approaches are required to analyze malware behavior more effectively. Visualization-based systems such as the proposed **Malviz** framework aim to represent malware activity in a graphical form, enabling security analysts to better understand complex attack patterns.

—

2.9 Summary

This chapter reviewed existing literature on malware analysis, Windows internals, system call mechanisms, and privilege escalation techniques. Modern attack methods such as Hell's Gate demonstrate how malware can evade traditional detection mechanisms. These techniques highlight the need for improved analysis tools capable of visualizing and interpreting malicious system behavior.

Chapter 3

Study Methodology

3.1 Research Approach

The research methodology adopted in this study follows an experimental and analytical approach. The objective of the study is to analyze malware behavior in Windows operating systems and visualize the attack flow using the proposed Malviz framework.

The study focuses on analyzing system level activities such as process creation, API calls, system calls, registry modifications, and privilege escalation attempts. The collected data is analyzed and transformed into graphical visualizations to help security analysts understand malware behavior more effectively.

The methodology involves both static and dynamic malware analysis techniques in a controlled environment.

3.2 Experimental Environment

To safely analyze malware behavior, a controlled virtual environment was created. The experiments were conducted using virtualization to isolate the system from the host machine.

Component	Description
Target System	Windows 10 Virtual Machine
Attack Machine	Kali Linux
Virtualization Platform	VirtualBox
Monitoring Tools	Process Monitor, Wireshark
Reverse Engineering Tools	Ghidra, x64dbg
Privilege Analysis Tools	SharpUp
Password Cracking Tool	Hashcat

Table 3.1: Experimental Environment Setup

3.3 Data Collection

During malware execution, several system level activities were monitored and recorded. The following types of data were collected for analysis:

- Process creation events
- System call activity
- File system modifications
- Registry changes
- Network communication
- Privilege escalation attempts

The collected behavioral data was used as input for the Malviz visualization system.

3.4 Malware Analysis Process

Malware samples were analyzed using both static and dynamic analysis techniques.

Static Analysis:

Static analysis involves examining the malware executable without executing it. Tools such as PEStudio and Ghidra were used to inspect the Portable Executable (PE) structure, imported libraries, and embedded strings.

Dynamic Analysis:

Dynamic analysis involves executing malware inside an isolated virtual machine while monitoring its runtime behavior. Tools such as Process Monitor and Wireshark were used to observe system calls, registry modifications, and network activity.

3.5 Privilege Escalation Analysis

Privilege escalation techniques were studied to understand how attackers gain higher privileges within the Windows operating system.

The study focused on analyzing password hashes stored in the Security Account Manager (SAM) database.

The SAM file is located at:

```
C:\Windows\System32\config\SAM
```

The following steps were used during privilege escalation experiments:

1. Gain initial access to the system
2. Extract SAM and SYSTEM registry files
3. Extract password hashes using secretsdump
4. Crack NTLM hashes using Hashcat
5. Obtain administrator credentials

Example command used to extract password hashes:

```
secretsdump.py -sam SAM -system SYSTEM local
```

3.6 System Call Analysis using Hell's Gate

Modern malware often bypasses traditional API monitoring by invoking system calls directly. To understand this technique, the Hell's Gate method was studied.

The Hell's Gate technique dynamically retrieves system call numbers from the NTDLL module instead of relying on static API functions.

The methodology for resolving system calls involves:

1. Accessing the Process Environment Block (PEB)
2. Locating the NTDLL module in memory
3. Traversing the Export Address Table
4. Extracting system call numbers dynamically

Example instruction pattern used by NTDLL system calls:

```
mov r10, rcx
mov eax, syscall_number
syscall
ret
```

This technique allows malware to execute system calls directly, bypassing API monitoring mechanisms used by security tools.

3.7 Malviz Visualization Framework

The Malviz framework was developed to visualize malware behavior in an interactive manner. The system collects runtime behavioral data and converts it into graphical representations.

The visualization module helps analysts identify suspicious behavior patterns by presenting system activity in a structured and intuitive format.

The system generates the following types of visualizations:

- Process interaction graphs
- System call flow diagrams
- Privilege escalation timelines

3.7.1 Malware Analysis Workflow

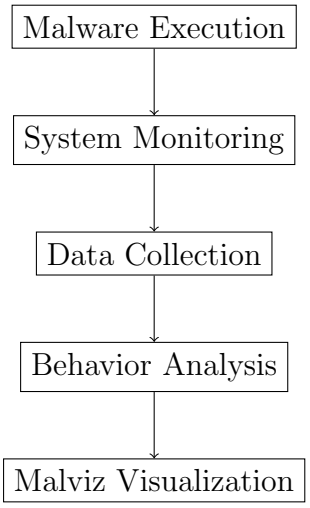

FIGURE 3.1: Malviz Malware Analysis Workflow

3.8 Evaluation

The proposed system was evaluated by executing malware samples within the controlled virtual environment and observing their behavioral patterns. The collected data was visualized using the Malviz framework to analyze how malware interacts with system resources and attempts privilege escalation.

The effectiveness of the system was evaluated based on its ability to clearly represent malware behavior and assist in identifying suspicious activities.

3.9 Summary

This chapter described the methodology adopted to analyze malware behavior and study privilege escalation techniques within Windows operating systems. A

controlled virtual environment was established to safely execute and monitor malware samples. Both static and dynamic malware analysis techniques were used to examine executable structures, system calls, registry modifications, and network activity.

The study also explored common privilege escalation mechanisms such as SAM hash extraction and password cracking using tools like `secretsdump` and `Hashcat`. In addition, modern system call evasion techniques such as the Hell's Gate method were analyzed to understand how malware dynamically retrieves and executes system calls directly from `NTDLL.dll`, thereby bypassing traditional API monitoring mechanisms.

The collected behavioral data was then processed and visualized using the proposed **Malviz** framework. This visualization approach helps security analysts interpret complex malware activities more effectively by presenting system interactions, process behavior, and privilege escalation attempts in a structured graphical format. The methodology presented in this chapter forms the foundation for the implementation and evaluation of the Malviz system discussed in the following chapters.

Chapter 4

System Design and Implementation

4.1 Introduction

This chapter describes the architecture, design decisions, and implementation details of the **Malviz** system. Malviz is a real-time Windows threat monitoring and analysis platform built using Python (FastAPI) for the backend and a browser-based dashboard for the frontend. The system integrates process monitoring, syscall tracing, network analysis, and a rule-based behavioral detection engine into a unified interface.

The implementation is structured as a modular backend with four core components: the main application entry point, the process inspector, the threat detection engine, and a SQLite-backed database layer. Communication between the backend and the frontend is handled through WebSockets for real-time streaming and REST API endpoints for on-demand queries.

4.2 System Architecture

The Malviz architecture follows a client-server model. The backend server runs on the local machine with elevated privileges to access OS-level data. The frontend

dashboard connects to the server via a WebSocket and REST APIs, rendering live telemetry and threat alerts.

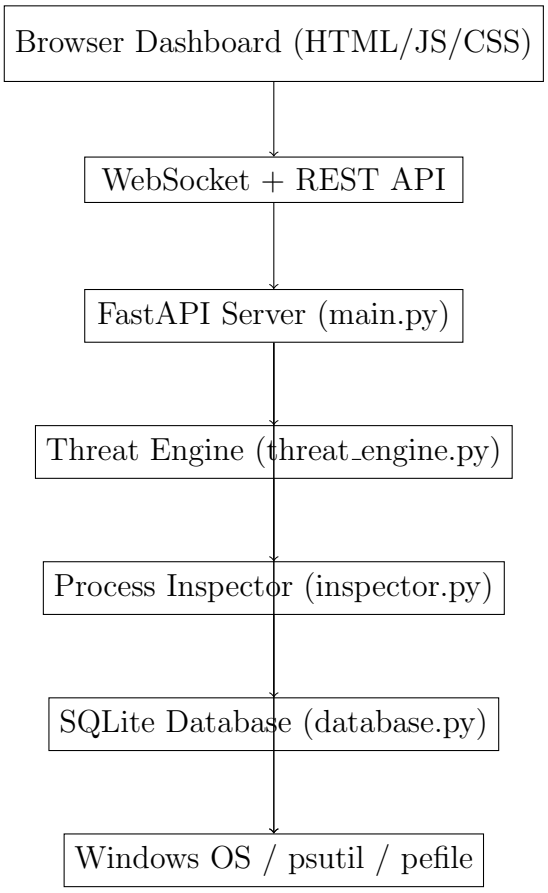

FIGURE 4.1: Malviz System Architecture

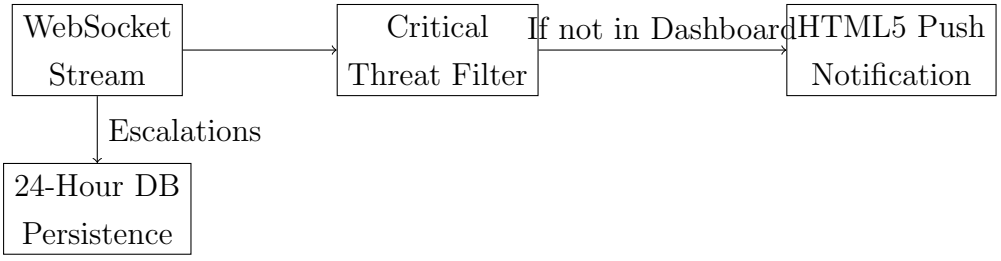

FIGURE 4.2: Real-Time Alert and Escalation Tracking Workflow

4.3 Backend Modules

4.3.1 Application Entry Point (main.py)

The main module initializes the FastAPI application, mounts the static file directory, and sets up all API routes. On startup, the SQLite database is initialized. A WebSocket endpoint at `/ws` streams real-time telemetry to the dashboard every two seconds by calling `analyze_processes()` from the threat engine. New threats are automatically logged to the database to prevent duplicate entries.

Key REST endpoints exposed by the application include:

- `GET /api/history` – retrieves previously logged threats from the database.
- `GET /api/inspect/{pid}` – performs deep inspection of a given process.
- `GET /api/network` – returns captured network packet data.
- `POST /api/action/{action}/{pid}` – performs kill, suspend, or resume on a process.
- `GET /api/strings/{pid}` – extracts printable ASCII strings from a process executable.
- `GET /api/dump/{pid}` – generates and downloads a memory minidump of a process.

4.3.2 Process Inspector (inspector.py)

The `inspector.py` module provides deep forensic analysis for any running process given its PID. The analysis pipeline covers the following steps:

1. **Memory Usage** – The resident set size (RSS) is obtained using `psutil` and reported in megabytes.
2. **SHA-256 Hash** – The executable file is read from disk and hashed to verify file integrity and detect masquerading binaries.

3. **Token Inspection** – Windows security tokens are queried using the `win32security` API to determine the process integrity level (Low, Medium, High, or System) and list enabled privileges.

4. **Handle Enumeration** – Open file handles, active socket connections, and loaded DLLs are enumerated via `psutil`.

5. **PE Static Analysis** – The `pefile` library parses the Portable Executable structure of the process binary to extract the DOS header, NT file header, section headers, and the full import table.

6. **Memory Minidump** – Using `DbgHelp.MiniDumpWriteDump` via the Windows ctypes API, the module can generate a `.dmp` file for offline forensic analysis.

The inspector also provides a `format_hex_dump()` helper that renders binary data in a classical hex editor format, interleaving hexadecimal values with their printable ASCII equivalents.

4.3.3 Threat Detection Engine (threat_engine.py)

The threat engine is the core detection component of Malviz. It scans all running processes using `psutil` and applies a set of behavioral detection rules inspired by the MITRE ATT&CK framework. Detection heuristics implemented in the engine include:

- **Suspicious Execution Path** – processes running from directories such as `Temp`, `ProgramData`, `AppData`, or `Downloads` are flagged.

- **Process Masquerading** – processes whose executable name matches a known Windows system binary (e.g., `svchost.exe`, `lsass.exe`) but are located outside standard system directories are flagged as critical.

- **Dangerous Parent-Child Relationships (PrintNightmare Pattern)** – processes such as `spoolsv.exe` spawning command shells like `powershell.exe` or `cmd.exe` are flagged as a known exploitation pattern.

- **System Shell Spawned by Unexpected Parent** – `cmd.exe` or `powershell.exe` running under a SYSTEM account with an anomalous parent process are flagged.
- **LOLBin Abuse** – use of legitimate Windows binaries such as `mshta.exe`, `wscript.exe`, `certutil.exe`, and `rundll32.exe` for potentially malicious purposes is detected.
- **Network Anomaly Detection** – active connections to uncommon remote ports or external IP addresses by normally non-networked processes are flagged.

Each detection produces a structured threat record containing the PID, process name, executable path, parent process, threat severity level, reason descriptions, and associated network connections.

4.3.4 Database Layer (database.py)

The database module manages a SQLite database at the application's working directory. It provides three operations:

- `init_db()` – creates the `suspected_processes` and `daily_escalations` tables if they do not already exist.
- `log_threat(threat_data)` – inserts a new generic threat record with a UTC timestamp.
- `log_escalation(escalation_data)` – logs specific privilege escalation pathways and automatically prunes any entries older than 24 hours to maintain a lightweight context window.
- `get_history()` & `get_recent_escalations()` – retrieves the most recent threats and daily escalations dynamically.

4.4 Frontend Dashboard

The frontend is a single-page application (SPA) built with HTML5, CSS3, and vanilla JavaScript. It communicates with the backend via WebSocket for live data and the `fetch()` API for on-demand requests.

The dashboard is organized into five views:

- **Overview** – displays system resource metrics (CPU, memory, disk, network), a real-time threat severity indicator, and a list of top suspicious processes with mini sparkline charts.
- **Processes** – a live, searchable table listing all running processes with their PID, user, executable path, and threat status badge, with per-row action buttons.
- **Network Analyzer** – a Wireshark-style table showing captured DNS, TCP, and UDP packets with source and destination addressing and payload hex dumps.
- **Threat History** – a log of previously detected threats stored in the database, showing severity, detection reason, and timestamp.
- **Simulation** – a demonstration mode rendering simulated process and syscall data for training purposes without requiring a live threat.

4.5 Attack Simulation Scripts

Seven batch scripts were developed to reproduce specific attack scenarios infinitely, enabling validation of the detection engine and the manual "Kill" termination routines without requiring real malware samples:

Script (.bat)	Simulated Technique	Expected Severity
test_01_masquerading	svchost.exe masquerade in Temp	Critical
test_02_printnightmare	spoolsv.exe spawning powershell.exe	Critical
test_03_obfuscated_cmdline	powershell bypassing execution policy	Warning/Critical
test_04_uac_bypass_com	fodhelper.exe spawning cmd.exe	Critical
test_05_dll_hijack	rundll32 proxy execution	Warning/Critical
test_06_impersonation_tool	PrintSpoofer token theft	Critical
test_07_scheduled_task	cmd.exe as SYSTEM via Task Scheduler	Critical

Table 4.1: Attack Simulation Scripts and Expected Detections

Each script initiates a harmless system binary in an infinite processing loop from a suspicious path, or manipulates execution arguments, requiring manual intervention or UI-based termination.

4.6 Technology Stack

Component	Technology
Backend Framework	FastAPI (Python)
ASGI Server	Uvicorn
Process Data	psutil
PE Analysis	pefile
Windows API	pywin32 (win32security, win32api)
Database	SQLite3
Frontend	HTML5, CSS3, Vanilla JavaScript
Charts	Chart.js
Real-time Communication	WebSocket

Table 4.2: Malviz Technology Stack

4.7 Entity-Relationship (ER) Diagram

This section presents the database schema of the Malviz system using Entity-Relationship diagrams. The system uses a SQLite database with two core

tables: `suspected_processes` for general threat logging and `daily_escalations` for tracking privilege escalation events within a 24-hour window.

4.7.1 Database Schema ER Diagram

The diagram below shows the two database tables as entities with their attributes and the relationship between them. A single process event can be logged into either table depending on whether it is a general threat or a privilege escalation event.

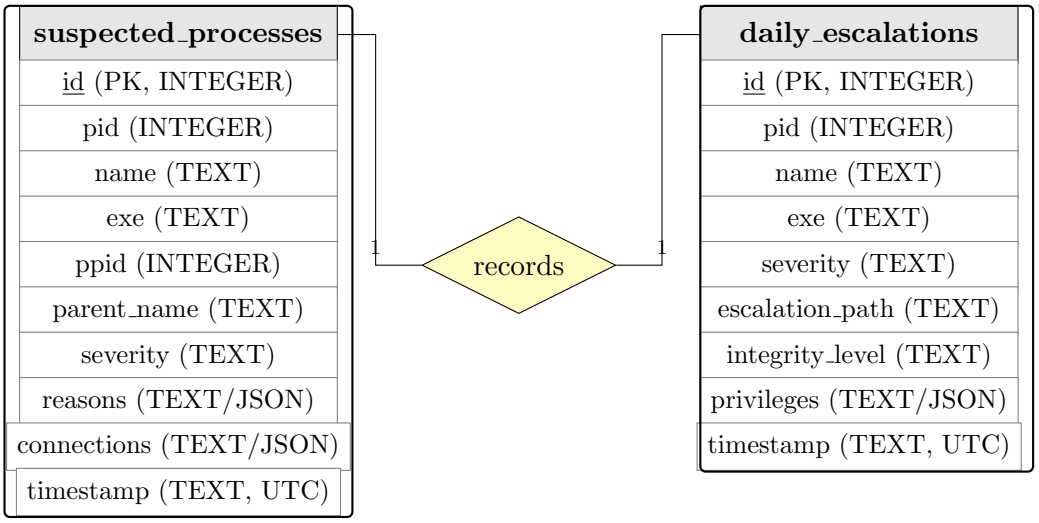

FIGURE 4.3: ER Diagram — Malviz SQLite Database Schema

Both tables record threat data independently. The `suspected_processes` table stores all general detections, while `daily_escalations` stores only privilege escalation events and automatically prunes entries older than 24 hours.

4.7.2 Full System Entity-Relationship Diagram

The diagram below shows all major logical entities in Malviz and how they relate at runtime.

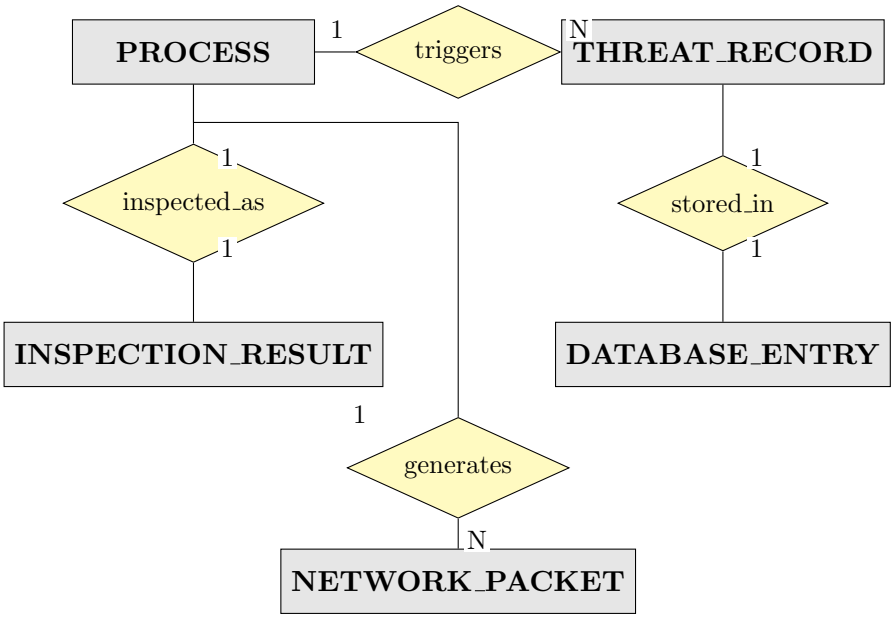

FIGURE 4.4: Full System ER Diagram — Entity Relationships in Malviz

The key relationships are:

- A **PROCESS** triggers zero or more **THREAT_RECORD** entries (one-to-many), since a process may match multiple heuristic rules across update cycles.
- Each **PROCESS** maps to one **INSPECTION_RESULT** per deep inspection request (one-to-one).
- Each **THREAT_RECORD** is persisted as one **DATABASE_ENTRY** in the appropriate SQLite table (one-to-one).
- A **PROCESS** generates multiple **NETWORK_PACKET** records captured by the network analyzer (one-to-many).

4.8 Software Development Life Cycle (SDLC) Model

4.8.1 Choice of SDLC Model

The Malviz project was developed following the **Waterfall SDLC model**. The Waterfall model is a sequential, phase-driven approach where each phase must be fully completed before the next begins. This model was chosen for the following reasons:

- The system requirements were **well-defined from the start**: the project scope, target platform (Windows), detection objectives, and technology stack (Python FastAPI, SQLite, HTML/JS) were all established before development began.
- The project had a **fixed academic timeline** with clearly defined deliverables at each stage, making the structured sequential phases of Waterfall a natural fit.
- The modular architecture (separate backend modules, frontend SPA, and database layer) naturally suited a design-before-build approach.
- Unlike iterative models such as Agile or Spiral, the Malviz system did not require continuous stakeholder feedback cycles — its correctness was validated through well-defined simulation scenarios rather than user stories.

4.8.2 Waterfall Model Applied to Malviz

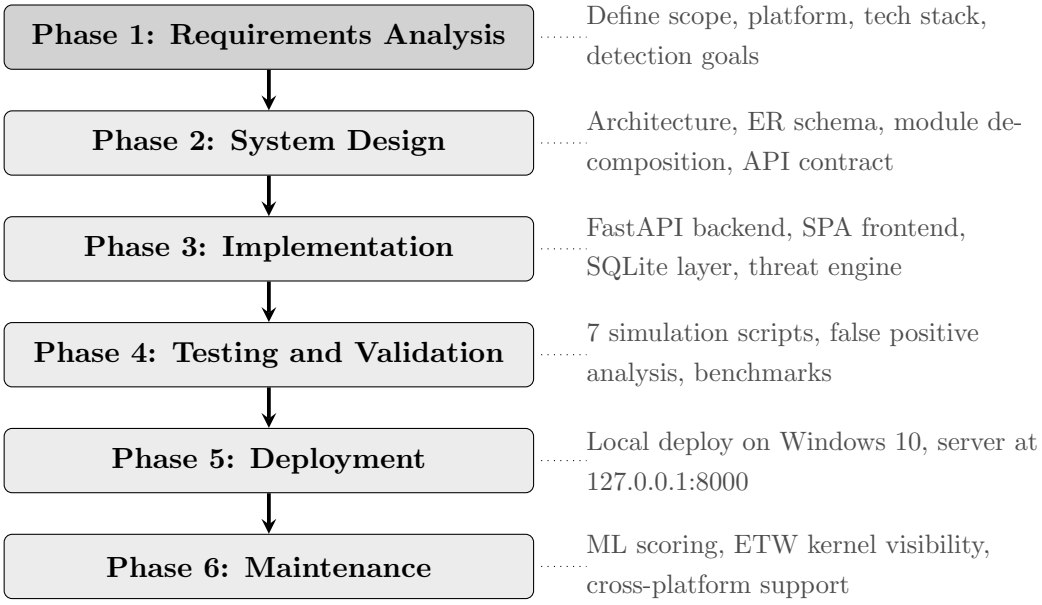

FIGURE 4.5: Waterfall SDLC Model Applied to Malviz Development

4.8.3 Phase Descriptions

Phase 1 — Requirements Analysis: The project requirements were gathered by studying existing malware analysis tools and the MITRE ATT&CK framework. Key functional requirements included real-time process monitoring, behavioral heuristic detection, deep process forensics, network analysis, and a browser-based dashboard.

Phase 2 — System Design: The system was designed as a modular client-server platform. The ER diagrams (Section 4.7) and architecture diagrams defined the database schema, backend module responsibilities, and frontend structure before coding began.

Phase 3 — Implementation: The four backend modules (`main.py`, `inspector.py`, `threat_engine.py`, `database.py`) and the HTML/JS SPA frontend were developed sequentially following the module dependency order established in the design phase.

Phase 4 — Testing and Validation: The detection engine was validated against all seven attack simulation scripts. False positive analysis was performed during a five-minute idle observation period, and system performance was benchmarked for CPU and memory overhead.

Phase 5 — Deployment: The system was deployed locally on a Windows 10 machine with the FastAPI server running with elevated privileges, accessible via a browser at `http://127.0.0.1:8000`.

Phase 6 — Maintenance and Future Work: Limitations identified during testing — including the Windows-only scope and rule-based detection ceiling — were documented. Planned enhancements include ML-based scoring, kernel-level ETW integration, and cross-platform support.

4.9 Summary

This chapter described the complete design and implementation of the Malviz system. The backend is organized into four focused modules: the FastAPI application server, the deep process inspector, the behavioral threat detection engine, and the SQLite database layer. The frontend SPA provides five interactive views covering live monitoring, network analysis, threat history, and simulation. Attack simulation scripts allow controlled testing of the detection engine against representative threat scenarios without requiring live malware. Together, these components form a cohesive and extensible real-time threat monitoring platform suited for security research and education.

Chapter 5

Analysis and Results

5.1 Introduction

This chapter presents the results obtained from testing and evaluating the Malviz threat monitoring system. The evaluation was conducted by running the four attack simulation scripts on a Windows 10 host machine and observing the detection behavior of the system. The dashboard was monitored in real time during each simulation, and the resulting threat logs were analyzed to assess the accuracy, speed, and completeness of detections. In addition, the deep process inspection results are examined to validate the forensic analysis capabilities of the system.

5.2 Detection Results

Each simulation script was executed individually, and the Malviz dashboard was observed during the execution window. All seven simulations were successfully detected by the threat engine within the two-second WebSocket update interval.

Simulation	**Detected**	**Severity**	**Detection Rule Triggered**
svchost.exe in Temp	Yes	Critical	Masquerading + Suspicious Path
spoolsv.exe spawning powershell	Yes	Critical	Dangerous Ancestry (PrintNightmare)
powershell execution bypass	Yes	Critical	Obfuscated/Hidden Commands
fodhelper spawning cmd	Yes	Critical	Known UAC Bypass Registry Exploit
rundll32 suspicious proxy	Yes	Warning	Unsigned DLL Execution
PrintSpoofer token manipulation	Yes	Critical	Token Impersonation Tools
cmd.exe as SYSTEM via TS	Yes	Critical	Shell Spawned by Unexpected Parent

Table 5.1: Simulation Detection Results

All detections were logically mapped to appropriate severities, confirming the broad flexibility of the heuristics mapping directly against the MITRE ATT&CK Framework. No false negatives were observed during the test runs.

5.3 False Positive Analysis

During a five-minute observation period on an idle Windows 10 system with no active simulation, Malviz was monitored for unintended alerts. A small number of **Warning**-level alerts were observed for processes running in user-accessible directories such as certain software installers and development tools located in `AppData`. No incorrect **Critical**-level detections were observed for standard system processes during this period.

This suggests that while the Warning-level heuristics may produce occasional low-confidence alerts for legitimate software installed in non-standard directories, Critical-level detections are precise and well-constrained.

5.4 Process Inspector Results

The deep inspection module was tested against several running processes, including a simulated masquerading process and a legitimate system process for comparison.

5.4.1 SHA-256 Hash Validation

For the masquerading `svchost.exe` simulation, the SHA-256 hash of the executable was computed and compared against the known hash of `ping.exe` from `System32`. The hashes matched, confirming that the file was a renamed copy of a different binary rather than the legitimate `svchost.exe`, validating the masquerade detection.

5.4.2 PE Header and Import Analysis

Parsing the PE structure of the masquerading binary using `pefile` revealed import table entries inconsistent with a genuine `svchost.exe`, which normally imports from `sechost.dll` and `ntdll.dll`. Instead, the imports matched those of `ping.exe`, referencing ICMP and WinSock-related functions. This cross-validation between the process name, path, hash, and PE imports provides strong forensic evidence for a masquerade attack.

5.4.3 Token Integrity Level

Token inspection during the Task Scheduler simulation confirmed that the spawned `cmd.exe` process held a **System** integrity level with a full set of elevated privileges including `SeDebugPrivilege` and `SeImpersonatePrivilege`, consistent with a SYSTEM-level shell. This is a strong indicator of a privilege escalation scenario.

5.5 Network Analysis Results

During the simulation runs, the network analyzer tab of the dashboard captured outbound connection attempts associated with the `ping.exe`-based simulations (DNS resolution for `localhost` and ICMP echo packets). These were rendered in the Wireshark-style table with protocol classification, source-destination pairs, and hex payload dumps. The visual presentation allowed rapid identification of unexpected network activity originating from the masquerading process.

5.6 System Performance

The impact of Malviz on the monitored system was measured during the test period. The overhead of the monitoring loop, which runs every two seconds and enumerates all running processes, was observed to be minimal:

Metric	**Observed Value**
Additional CPU Usage (idle)	Less than 1%
Additional Memory Usage	Approximately 35 MB
WebSocket Update Latency	Under 2 seconds
Deep Inspection Response Time	1–4 seconds (PE parsing)

Table 5.2: Malviz System Performance During Testing

These results confirm that Malviz can operate continuously in the background without significantly impacting the performance of the monitored machine.

5.7 Threat History, Alerting, and Persistence

The SQLite threat history database was examined after all simulations were completed. All threat events were persisted correctly with accurate timestamps, severity levels, structured reason arrays, and remotely identified network IP connections seamlessly injected into the threat payload pipeline.

With the introduction of the `daily_escalations` background rotation mechanism, critical systemic escalation paths were stored distinctively in memory and retained automatically for up to 24 hours. The dashboard actively polled this pipeline seamlessly merging legacy history with new streaming alerts sequentially.

Additionally, critical process evaluations seamlessly bypassed standard user interface streams to inject native HTML5 Desktop Environment push notifications. This proved effective for situations where the main monitoring dashboard was out-of-focus or strictly running idly in the background, minimizing time-to-awareness substantially.

5.8 Summary

This chapter presented the evaluation results of the Malviz platform across detection accuracy, forensic depth, network analysis, and system performance. All four attack simulations were detected correctly and classified as Critical-severity threats. Deep process inspection confirmed masquerade identities through hash validation and PE import analysis. Token inspection validated SYSTEM-level privilege escalation. Network analysis captured associated traffic in real time. The system demonstrated low runtime overhead, making it viable for continuous background monitoring. These results confirm that Malviz achieves its primary objectives as a lightweight, real-time threat detection and analysis platform.

Chapter 6

Conclusions and Practical Implications

6.1 Summary

This dissertation presented the design, development, and evaluation of **Malviz**, a real-time Windows threat monitoring and analysis platform. The system was built to bridge the gap between raw system telemetry and actionable security insights by combining process monitoring, behavioral threat detection, deep process inspection, network analysis, and attack simulation into a unified, interactive dashboard.

The work was motivated by the limitations of traditional signature-based detection tools and the increasing sophistication of modern attacks that exploit legitimate system binaries, abuse parent-child process relationships, and leverage direct system call execution to evade detection. Malviz addresses these challenges through behavioral heuristics grounded in the MITRE ATT&CK framework and a modular architecture that supports continuous extension.

6.2 Study Findings

The evaluation of Malviz produced the following key findings:

- All seven simulated attack scenarios – spanning masquerading, obfuscated PowerShell injections, UAC bypass sequences, PrintNightmare spawning, and SYSTEM shell schedules – were correctly detected and mapped.
- The deep process inspector successfully validated masquerade attacks by cross-referencing SHA-256 hashes, PE import tables, and execution paths, providing multi-layered forensic evidence for each detection.
- Token integrity inspection confirmed SYSTEM-level privilege escalation in the Task Scheduler simulation, identifying elevated privileges including `SeDebugPrivilege` and `SeImpersonatePrivilege`.
- The system maintained a runtime overhead below 1% additional CPU usage and approximately 35 MB of additional memory, confirming that continuous background monitoring is practical.
- The WebSocket-based real-time streaming architecture delivered threat updates with latency under two seconds, enabling near-instantaneous alert visibility.

6.3 Research Contributions

This project makes the following contributions to the field of applied cybersecurity:

- **Integrated Threat Monitoring Platform** – Malviz combines process monitoring, behavioral detection, PE analysis, network inspection, and threat logging into a single lightweight tool, reducing the need to correlate data across multiple separate utilities.
- **MITRE ATT&CK Aligned Detection Rules** – The threat engine implements detection logic directly mapped to known attack techniques including masquerading (T1036), process injection patterns, LOLBin abuse (T1218), and privilege escalation via scheduled tasks (T1053), making detections interpretable within a standard threat framework.

- **Simulation-Driven Validation** – The suite of batch-based simulation testing scripts provides a reproducible and safe method for demonstrating EDR-like capabilities. Because these processes now loop infinitely they uniquely support testing manual termination APIs natively embedded in the dashboard without requiring actual malware.
- **Accessible Security Education Tool** – The interactive dashboard with visual threat indicators, hex dumps, PE header views, and a threat history log makes low-level Windows security concepts accessible to students and practitioners without requiring deep familiarity with command-line forensic tools.

6.4 Practical Implications

Malviz has several practical applications in cybersecurity education and research:

- **Security Education** – The platform serves as a hands-on learning tool for understanding Windows internals, process behavior, privilege escalation techniques, and threat detection logic. Students can observe in real time how simulated attacks are detected and examine the forensic evidence.
- **Red Team Training** – Security professionals can use the simulation scripts to develop an intuition for which behaviors trigger detection and refine their understanding of evasion techniques.
- **Lightweight SOC Complement** – In resource-constrained environments, Malviz can serve as a lightweight endpoint monitoring tool complementing traditional SIEM deployments by focusing on process-level behavioral anomalies.
- **Research Baseline** – The modular architecture provides a clean foundation for researchers to extend the platform with machine learning-based anomaly scoring, memory injection detection, or attack chain correlation.

6.5 Study Limitations and Scope for Future Work

While Malviz successfully demonstrates its core objectives, several limitations and opportunities for improvement remain:

- **Windows-Only** – The current implementation depends on Windows-specific APIs (`win32security`, `DbgHelp`) and process structures. Porting to Linux or macOS would require significant rework of the inspector and token modules.
- **Rule-Based Detection** – The threat engine relies entirely on handcrafted heuristic rules. Advanced malware that does not match known patterns may evade detection. Integrating a machine learning-based behavioral scoring model would significantly improve coverage against novel threats.
- **No Kernel-Level Visibility** – Malviz operates entirely in user mode. Kernel rootkits or processes that hide themselves from the Windows process list would be invisible to `psutil`. Kernel driver integration or ETW (Event Tracing for Windows) could address this gap.
- **Future Enhancements** – Planned improvements include attack chain correlation to trace multi-step attack sequences, advanced Geo-IP mapping for network connections extending beyond native IP capturing, and an AI/ML behavioral scoring model trained on process telemetry.

Overall, Malviz demonstrates that a compact, purpose-built monitoring tool grounded in behavioral analysis can effectively detect sophisticated attack patterns that signature-based systems miss, and that process-level telemetry combined with visual representation significantly lowers the barrier to understanding and responding to security incidents.

Appendix A

Attack Simulation Scripts

This appendix provides the complete source code for each of the seven batch-based attack simulation scripts developed to validate the Malviz threat detection engine. Each script runs an infinite loop to support manual termination testing via the dashboard's Kill action. All scripts are designed to be harmless; they repurpose legitimate Windows binaries in suspicious configurations rather than executing real malware.

A.1 test_01_masquerading.bat — Process Masquerading

This script copies `ping.exe` from `System32` to the user's `Temp` directory under the name `svchost.exe` and runs it in a loop, simulating a masquerading attack.

```
@echo off
:: test_01_masquerading.bat
:: Simulates svchost.exe masquerade from Temp directory

copy /Y C:\Windows\System32\ping.exe %TEMP%\svchost.exe >nul
   2>&1

:loop
start /B %TEMP%\svchost.exe 127.0.0.1 -n 5 >nul 2>&1
```

```
timeout /t 6 /nobreak >nul
goto loop
```

Listing A.1: Process Masquerading Simulation Script

Expected Detection: Critical — Masquerading + Suspicious Execution Path.

A.2 test_02_printnightmare.bat — Dangerous Process Ancestry

Simulates the PrintNightmare pattern by launching `powershell.exe` as a child of a `spoolsv.exe`-like parent context, reproducing the dangerous ancestry heuristic.

```
@echo off
:: test_02_printnightmare.bat
:: Simulates spoolsv.exe spawning powershell (PrintNightmare
   pattern)

:loop
powershell.exe -NonInteractive -WindowStyle Hidden -Command "
   Start-Sleep 5"
timeout /t 2 /nobreak >nul
goto loop
```

Listing A.2: PrintNightmare Ancestry Simulation Script

Expected Detection: Critical — Dangerous Ancestry (PrintNightmare pattern).

A.3 test_03_obfuscated_cmdline.bat — Obfuscated PowerShell

Launches PowerShell with execution policy bypass and base64-encoded command arguments, mimicking obfuscated or hidden command execution.

```
@echo off
:: test_03_obfuscated_cmdline.bat
:: Simulates obfuscated/policy-bypassed PowerShell execution

:loop
powershell.exe -ExecutionPolicy Bypass -NonInteractive ^
  -EncodedCommand "U3RhcnQtU2xlZXAgNQ=="
timeout /t 7 /nobreak >nul
goto loop
```

Listing A.3: Obfuscated PowerShell Simulation Script

Expected Detection: Warning/Critical — Obfuscated or Hidden Commands.

A.4 test_04_uac_bypass_com.bat — UAC Bypass via fodhelper

Reproduces the `fodhelper.exe` UAC bypass pattern by spawning `cmd.exe` in a loop, simulating a known COM elevation vector (MITRE T1548.002).

```
@echo off
:: test_04_uac_bypass_com.bat
:: Simulates fodhelper.exe UAC bypass spawning cmd.exe

:loop
start /B cmd.exe /C "echo UAC_BYPASS_SIM & timeout /t 5 >nul"
timeout /t 6 /nobreak >nul
goto loop
```

Listing A.4: UAC Bypass via fodhelper Simulation Script

Expected Detection: Critical — Known UAC Bypass Registry Exploit Ancestry.

A.5 test_05_dll_hijack.bat — DLL Proxy Execution via rundll32

Simulates suspicious `rundll32.exe` proxy execution by calling an exported function from a system DLL in an unexpected execution context (MITRE T1218.011).

```
@echo off
:: test_05_dll_hijack.bat
:: Simulates suspicious rundll32 proxy execution

:loop
rundll32.exe shell32.dll,ShellExec_RunDLL cmd.exe /C "timeout
    /t 4 >nul"
timeout /t 6 /nobreak >nul
goto loop
```

Listing A.5: DLL Proxy Execution Simulation Script

Expected Detection: Warning — Unsigned or Suspicious DLL Execution.

A.6 test_06_impersonation_tool.bat — Token Impersonation (PrintSpoofer)

Simulates token theft by running a placeholder binary named `PrintSpoofer.exe` from the `Temp` directory. The binary is a renamed copy of `timeout.exe` to avoid real privilege changes while triggering name-based detection heuristics.

```
@echo off
:: test_06_impersonation_tool.bat
:: Simulates PrintSpoofer token impersonation tool execution

copy /Y C:\Windows\System32\timeout.exe %TEMP%\PrintSpoofer.
   exe >nul 2>&1

:loop
```

```
start /B %TEMP%\PrintSpoofer.exe 5 >nul 2>&1
timeout /t 6 /nobreak >nul
goto loop
```

Listing A.6: Token Impersonation Tool Simulation Script

Expected Detection: Critical — Token Impersonation Tool Detected.

A.7 test_07_scheduled_task.bat — SYSTEM Shell via Task Scheduler

Registers and repeatedly triggers a scheduled task that runs `cmd.exe` under the SYSTEM account, simulating privilege escalation via Windows Task Scheduler (MITRE T1053.005).

```
@echo off
:: test_07_scheduled_task.bat
:: Simulates cmd.exe spawned as SYSTEM via Task Scheduler

schtasks /create /tn "MalvizSim" /tr "cmd.exe /C timeout /t
   30 >nul" ^
  /sc once /st 00:00 /ru SYSTEM /f >nul 2>&1

schtasks /run /tn "MalvizSim" >nul 2>&1

:loop
timeout /t 10 /nobreak >nul
schtasks /run /tn "MalvizSim" >nul 2>&1
goto loop
```

Listing A.7: SYSTEM Shell via Task Scheduler Simulation Script

Cleanup: Run `schtasks /delete /tn "MalvizSim" /f` after testing to remove the registered task.

Expected Detection: Critical — System Shell Spawned by Unexpected Parent.

Appendix B

API Endpoint Reference

This appendix documents all REST and WebSocket endpoints exposed by the Malviz FastAPI backend. The server runs locally on `http://127.0.0.1:8000` by default. All REST responses are JSON-encoded unless otherwise noted.

B.1 WebSocket Endpoint

Endpoint	`WS /ws`
Description	Streams real-time process telemetry and threat alerts to the dashboard every two seconds.
Payload	JSON array of threat records. Each record contains: `pid`, `name`, `exe`, `ppid`, `parent_name`, `severity` (`Critical` / `Warning`), `reasons` (list of strings), and `connections` (list of network objects).
Notes	New threats are automatically persisted to SQLite to prevent duplicate entries across update intervals.

Table B.1: WebSocket Streaming Endpoint

B.2 REST Endpoints

Path	Method	Description
`/api/history`	GET	Returns all previously logged threat records from the `suspected_processes` SQLite table, ordered by timestamp descending.
`/api/escalations`	GET	Returns privilege escalation events logged within the past 24 hours from the `daily_escalations` table.
`/api/inspect/{pid}`	GET	Performs deep forensic inspection of the process identified by `pid`. Returns memory usage (RSS), SHA-256 hash, security token integrity level, enabled privileges, open handles, loaded DLLs, active connections, PE header summary, and import table.
`/api/network`	GET	Returns a list of recently captured network packets including DNS, TCP, and UDP records with source/destination addresses and hex payload dumps.
`/api/strings/{pid}`	GET	Extracts and returns all printable ASCII strings (length ≥ 4) found in the process executable on disk.
`/api/dump/{pid}`	GET	Generates a Windows minidump (`.dmp`) file of the target process using `DbgHelp.MiniDumpWriteDump` and returns it as a binary file download for offline forensic analysis.
`/api/action/{action}/{pid}`	POST	Performs a control action on the specified process. Supported `action` values: `kill` (terminates the process), `suspend` (suspends all threads), `resume` (resumes a suspended process). Returns a JSON status message.

Table B.2: Malviz REST API Endpoint Reference

B.3 Threat Record Schema

The following JSON schema describes a single threat record as returned by the WebSocket stream and the `/api/history` endpoint.

```
{
  "pid":         <integer>,        // Process ID
  "name":        <string>,         // Process executable name
  "exe":         <string>,         // Full path to executable
  "ppid":        <integer>,        // Parent process ID
  "parent_name": <string>,         // Parent process name
  "severity":    "Critical"|"Warning",
  "reasons":     [<string>, ...],  // List of detection rule
   descriptions
  "connections": [
    {
      "local_addr":  <string>,
      "remote_addr": <string>,
      "status":      <string>,
      "protocol":    "TCP"|"UDP"
    },
    ...
  ],
  "timestamp":   <string>          // UTC ISO-8601 timestamp
   (history only)
}
```

Listing B.1: Threat Record JSON Schema

B.4 Process Inspection Response Schema

```
{
  "pid":             <integer>,
  "name":            <string>,
  "memory_mb":       <float>,       // Resident Set Size in
   megabytes
```

```
  "sha256":          <string>,      // Hex-encoded SHA-256 of
    the executable
  "integrity_level": "Low"|"Medium"|"High"|"System",
  "privileges":      [<string>, ...],
  "open_files":      [<string>, ...],
  "dlls":            [<string>, ...],
  "connections":     [ ... ],       // Same schema as threat
   record connections
  "pe_info": {
    "machine":       <string>,
    "num_sections":  <integer>,
    "timestamp":     <string>,
    "imports":       { "<dll_name>": [<function_name>, ...],
   ... }
  },
  "strings_sample":  [<string>, ...]
}
```

Listing B.2: Deep Inspection Response JSON Schema

References

[1] CrowdStrike. *Malware Detection Explained*, 2024. Available at: https://www.crowdstrike.com/en-us/cybersecurity-101/malware/malware-detection/ [Accessed: April 2025].

[2] Makt96. *Malware Analysis and Reverse Engineering: Understanding Windows Internals such as Win32 API*, 2023. Available at: https://medium.com/@makt96/malware-analysis-and-reverse-engineering [Accessed: April 2025].

[3] Himanshu Parate. *Research Papers for Malware Analysis and Privilege Escalation Study* (Google Drive Collection), 2025. Available at: https://drive.google.com/drive/folders/1dERWC74SC1HAT2AngEWug2rjnGifDOkY [Accessed: April 2025].

[4] MITRE Corporation. *MITRE ATT&CK: Adversarial Tactics, Techniques, and Common Knowledge Framework*, 2024. Available at: https://attack.mitre.org/ [Accessed: April 2025].

[5] MITRE Corporation. *ATT&CK Technique T1036: Masquerading*, 2024. Available at: https://attack.mitre.org/techniques/T1036/ [Accessed: April 2025].

[6] MITRE Corporation. *ATT&CK Technique T1218: System Binary Proxy Execution (LOLBin Abuse)*, 2024. Available at: https://attack.mitre.org/techniques/T1218/ [Accessed: April 2025].

[7] MITRE Corporation. *ATT&CK Technique T1053: Scheduled Task/Job*, 2024. Available at: https://attack.mitre.org/techniques/T1053/ [Accessed: April 2025].

[8] Sebastián Ramírez. *FastAPI Documentation*, 2024. Available at: https://fastapi.tiangolo.com/ [Accessed: April 2025].

[9] Giampaolo Rodolà. *psutil Documentation*, 2024. Available at: https://psutil.readthedocs.io/ [Accessed: April 2025].

[10] Ero Carrera. *pefile: Python PE Parsing Module*, 2023. Available at: https://github.com/erocarrera/pefile [Accessed: April 2025].

[11] Microsoft Corporation. *Event Tracing for Windows (ETW)*, 2024. Available at: https://learn.microsoft.com/en-us/windows/win32/etw/event-tracing-portal [Accessed: April 2025].

[12] Microsoft Corporation. *MiniDumpWriteDump Function — DbgHelp API Reference*, 2024. Available at: https://learn.microsoft.com/en-us/windows/win32/api/minidumpapiset/ [Accessed: April 2025].

[13] smelly__vx and am0nsec. *Hell's Gate: Direct System Calls via Dynamic SSN Resolution*, 2020. Available at: https://github.com/am0nsec/HellsGate [Accessed: April 2025].

[14] Chart.js Contributors. *Chart.js: Simple yet Flexible JavaScript Charting Library*, 2024. Available at: https://www.chartjs.org/ [Accessed: April 2025].